

Threat Model and Secure Configuration

Fictional Student Academic Portal – Defensive Cybersecurity Lab

Environment: Fictional defensive lab. Testing should be limited to localhost or an isolated VM; do not scan external systems.

1. Introduction

This threat-model exercise analyzes a fictional Student Academic Portal used by students, faculty and administrators. The purpose is to identify assets, trust boundaries, realistic abuse cases and security controls, then prioritize hardening actions based on likelihood and impact.

2. Application Description

The portal provides authenticated access to student profiles, marks, attendance and assignment files. Faculty can manage academic information, while administrators manage users and privileged functions.

3. System Architecture and Trust Boundaries

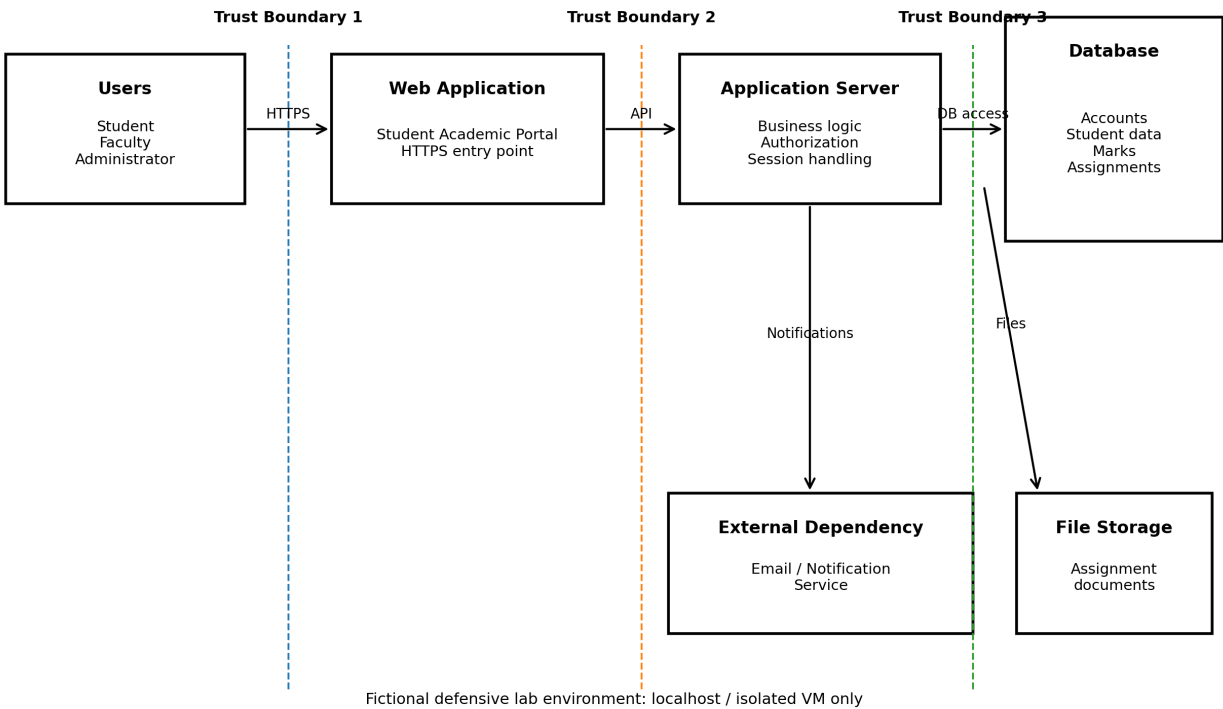


Figure 1. Threat-model architecture for the fictional Student Academic Portal.

Trust Boundary 1 separates users from the web application. Trust Boundary 2 separates the web-facing layer from backend business logic. Trust Boundary 3 separates application services from the database and protected data stores. Notification and file-storage services are additional controlled dependencies.

Asset	Description	Owner
Student credentials	Username, passwords and authentication information	Student / Institution
Student personal data	Name, email, contact and profile information	Student / Institution
Academic records	Marks, grades and attendance information	Institution
Assignment files	Files submitted by students and managed by faculty	Student / Faculty
Session tokens	Information used to maintain authenticated sessions	Application
Faculty/Admin accounts	Privileged accounts with additional functions	Institution
Database	Central storage for portal data	Institution

Category	Threat / Abuse Case	Potential Impact
Spoofing	Attacker obtains or guesses a user's password and logs in.	Account takeover and unauthorized access
Tampering	Unauthorized user attempts to modify marks or other records.	Academic record integrity is affected
Repudiation	A user disputes a sensitive action because activity was not logged adequately.	Difficult investigation and accountability
Information Disclosure	Unauthorized user accesses another student's personal or academic information.	Privacy breach and data exposure
Denial of Service	Excessive requests make the portal unavailable to legitimate users.	Service disruption
Elevation of Privilege	A normal student account attempts to access faculty/admin functions.	Unauthorized privileged actions

4. Assets and Owners

5. STRIDE Threat Analysis

6. Abuse Cases

7.1 Account takeover

Scenario: An attacker repeatedly attempts credentials against the login function. If a password is guessed or reused, the attacker may obtain access to the student's account.

Mitigation: Use strong password controls, secure password hashing, rate limiting, temporary delays/lockout, monitoring and MFA where appropriate.

7.2 Unauthorized grade modification

Scenario: A student attempts to invoke a faculty-only function to modify marks.

Mitigation: Enforce server-side role-based authorization and log all sensitive academic-record changes.

7.3 Student information exposure

Scenario: A user attempts to access another student's record by changing an identifier in a request or using an unauthorized endpoint.

Mitigation: Enforce object-level authorization and return only information the authenticated user is permitted to see.

7.4 Session compromise

Scenario: A stolen or improperly protected session token is used to access an active account.

Mitigation: Use secure cookie attributes, session expiration and invalidation after logout.

7.5 Privilege escalation

Scenario: A normal account attempts to access administrator functions.

Mitigation: Apply least privilege and server-side authorization checks for every privileged action.

7.6 Service disruption

Scenario: A source sends excessive requests to consume application resources.

Mitigation: Apply rate limiting, request throttling and resource controls appropriate to the isolated lab application.

Priority	Threat	Likelihood	Impact	Risk	Reason
1	Account takeover / credential attack	High	High	Critical	Login endpoints are common targets; compromise exposes account data and functions.
2	Unauthorized grade modification	Medium	High	High	Academic records require integrity and should be changed only by authorized roles.
3	Student information exposure	Medium	High	High	Personal and academic data should only be accessible to authorized users.

Priority	Threat	Likelihood	Impact	Risk	Reason
4	Session compromise	Medium	High	High	A stolen active session can bypass normal login controls.
5	Privilege escalation	Medium	High	High	Improper authorization could allow student access to faculty/admin functions.
6	Service disruption	Medium	Medium	Medium	Excessive requests could reduce availability of the portal.
7	Insufficient audit logging	Low	Medium	Low	Missing logs can make security investigations difficult.

7. Risk Assessment

Priority	Control	Implementation / Recommendation	Verification
1	Authentication protection	Strong password policy, secure password hashing, login rate limiting, temporary delay/lockout for repeated failures, and MFA where appropriate.	Use the isolated lab to test repeated failed logins and confirm rate limiting and logging.
2	Role-based access control	Separate Student, Faculty and Administrator permissions. Enforce authorization on the server for every privileged action.	Verify a Student account cannot access Faculty/Admin functions.
3	Academic-record protection	Allow mark changes only to authorized roles; validate requests server-side; log sensitive changes.	Perform a controlled test change and confirm authorization and audit logging.
4	Data protection	Use HTTPS; restrict database access; minimize sensitive data exposure; encrypt sensitive data where appropriate.	Inspect traffic/configuration in the isolated environment and verify database permissions.
5	Session security	Use secure, HttpOnly and appropriate SameSite cookie settings; expire sessions; invalidate sessions on logout.	Inspect session cookie attributes and verify logout invalidates the session.
6	Input validation	Validate input on the server and safely handle unexpected values and errors.	Submit controlled invalid inputs in the lab and verify safe rejection.
7	Monitoring and logging	Record authentication failures, privilege changes and academic-record modifications. Protect logs from unauthorized modification.	Perform test actions and confirm expected events appear in logs.
8	Availability controls	Apply request throttling/rate limits and resource limits appropriate to the application.	Generate controlled test traffic in the lab and verify the service remains usable.

8. Prioritized Hardening Plan

Control	Verification Step	Expected Result
Authentication	Attempt repeated failed logins in the isolated lab.	Requests are rate-limited/delayed and events are logged.
Authorization	Use a Student test account to request a Faculty/Admin function.	Request is denied by server-side authorization.
Record integrity	Attempt a controlled unauthorized change to a grade.	Change is rejected and the attempt is logged.
Session security	Inspect the session cookie after login.	Appropriate Secure/HttpOnly/SameSite settings are present.
Data protection	Check application responses for unnecessary sensitive information.	Only required data is returned.
Logging	Perform login and privileged test actions.	Relevant security events are recorded.
Availability	Send controlled repeated requests in the lab.	Rate limiting prevents excessive load from overwhelming the service.

9. Verification Checklist

10. Recommended Evidence

Keep the threat-model diagram, report, hardening checklist and any optional screenshots from the isolated lab in the same repository or folder. Redact passwords, tokens, personal information and secrets.

11. Conclusion

The threat model identifies authentication, authorization, academic-record integrity, data confidentiality, session security, availability and monitoring as key security areas. The hardening plan prioritizes account and privilege protection, followed by data, session, validation, monitoring and availability controls. Verification should remain within the supplied localhost or isolated-VM defensive environment.